

Skript: Passwortsicherheit

Kantonsschule im Lee

Thema: Passwortsicherheit, Entropie & Best Practices

Fach: Informatik

Autor: Laurin Ott

Datum: 31. Juli 2026

Inhaltsverzeichnis

1	Einleitung	2
2	Grundlegende Begriffe und Angriffsarten	2
3	Mathematische Grundlage: Die Passwort-Entropie	2
3.1	Beispielrechnung	2
3.2	Fazit der Berechnung	3
4	Aktuelle Richtlinien und Best Practices	3
	Literaturverzeichnis	4
	Glossar	4
	Akronyme	4

1 Einleitung

In fast allen IT-Systemen bilden Passwörter die erste Hürde gegen unbefugten Zugriff. In der Praxis zeigt sich jedoch immer wieder, dass schwache, kompromittierte oder mehrfach genutzte Passwörter eine der grössten Sicherheitslücken darstellen. Dieses Skript gibt einen Überblick über die mathematischen Grundlagen der Passwortstärke und fasst die aktuellen Empfehlungen zur Absicherung digitaler Identitäten zusammen [1].

2 Grundlegende Begriffe und Angriffsarten

In der Authentisierung und Passwortsicherheit spielen verschiedene Konzepte und Bedrohungen eine entscheidende Rolle:

Neben dem rein mathematischen **Brute-Force-Angriff** nutzen Angreifer in der Praxis sehr häufig ein **Dictionary Attack (Wörterbuchangriff)**, bei dem gezielt Listen mit geläufigen Wörtern, Namen und bekannten Daten durchprobiert werden. Um diesen Methoden zu entgehen, ist eine hohe **Entropie** entscheidend. Zusätzlich schützt moderne **Multi-Faktor-Authentisierung (MFA)** (z. B. eine Bestätigung direkt auf dem **Smartphone**) effektiv vor unbefugtem Zugriff.

3 Mathematische Grundlage: Die Passwort-Entropie

Die Stärke eines **Passworts** gegenüber Offline-Angriffen lässt sich mathematisch über die Shannon-**Entropie** beschreiben. Sie gibt an, wie viele Versuche ein Angreifer im schlechtesten Fall benötigt, um den gesamten Suchraum zu durchsuchen.

Die Formel zur Berechnung der Entropie E (in Bit) lautet:

$$E = L \cdot \log_2(R)$$

Dabei stehen die Variablen für folgende Werte:

- L : Die Länge des **Passworts** (Anzahl der verwendeten Zeichen).
- R : Die Grösse des verfügbaren Zeichensatzes (z. B. Kleinbuchstaben, Grossbuchstaben, Zahlen, Sonderzeichen).

3.1 Beispielrechnung

- **8 Zeichen (nur Kleinbuchstaben)**: Bei $L = 8$ und einem Zeichensatz von $R = 26$ ergibt sich eine Entropie von:

$$E_8 = 8 \cdot \log_2(26) \approx 37,6 \text{ Bit}$$

- **Verdopplung auf 16 Zeichen (gleicher Zeichensatz)**: Bei $L = 16$ und $R = 26$ steigt die Entropie linear mit der Länge auf:

$$E_{16} = 16 \cdot \log_2(26) \approx 75,2 \text{ Bit}$$

3.2 Fazit der Berechnung

Da die Anzahl der auszuprobierenden Kombinationen im Hintergrund exponentiell mit 2^E wächst, schützt das Verlängern des **Passworts** um ein Vielfaches effektiver vor Angriffen als das krampfhaftes Einfügen von Sonderzeichen bei einem zu kurzen **Passwort**. Zudem verhindert ein langes, zufälliges Passwort, dass ein **Dictionary Attack** (Wörterbuchangriff) erfolgreich ist.

4 Aktuelle Richtlinien und Best Practices

Moderne Richtlinien haben sich von alten Regeln verabschiedet. Heute gelten folgende Hauptempfehlungen:

1. **Länge vor Komplexität:** Bevorzugung von **Passphrasen** aus mehreren zufälligen Wörtern. Selbst wenn Angreifer raffinierte Wörterbuchangriffe oder Kombinationen ausprobieren, bricht ein System bei langen Passphrasen (oft auch ohne erzwungene Sonderzeichen) ein, weil die schiere Länge den Suchraum unknackbar macht.
2. **Einsatz von **Passwort-Manager**:** Generierung und Verwaltung unikater Passwörter.
3. **Aktivierung von **MFA**:** Einrichtung eines zweiten Faktors (z.B. aufs Smartphone).

Literaturverzeichnis

- [1] National Institute of Standards and Technology (NIST). *Digital Identity Guidelines (NIST SP 800-63)*. 2024.

Glossar

Brute-Force-Angriff	Ein automatisierter Angriff, bei dem Programme alle möglichen Zeichenkombinationen systematisch durchprobieren.
Dictionary Attack (Wörterbuchangriff)	Ein gezielter Angriff, bei dem Listen mit gebräuchlichen Wörtern, Namen und bekannten Passwörtern systematisch getestet werden.
Entropie	Ein Mass aus der Informationstheorie für die Stärke und Zufälligkeit eines Passworts.
Passphrase	Eine längere Zeichenkette, oft bestehend aus mehreren zufälligen Wörtern, die als Passwort verwendet wird.
Passwort	Eine geheime Zeichenkette, die zur Authentisierung dient.
Passwort-Manager	Software zur sicheren Verwaltung und Generierung von Passwörtern.

Akronyme

MFA Multi-Faktor-Authentisierung.